

VPCard Remediation Response

Virtual Card Solution — Vulnerability Assessment Report v1.0 (18/09/2026), and VA-016 to VA-018 raised subsequently |
Response date: 29/09/2026

Remediation is applied in application source and pending deployment to the assessment environment. Please confirm the retest window before validation.

VA-001

Remediation: Upgraded next from 16.3.2 to 16.3.5. The sharp dependency override was also raised to 0.35.4, as the Next.js upgrade alone does not move the pinned transitive version.

VA-002

Remediation: Upgraded undici from 7.29.0 to 7.29.1. A Node.js runtime upgrade to 24.21.0 or later is additionally required, as Node bundles its own copy of undici (currently 7.18.2) used by all outbound application requests.

VA-003

Remediation: Not reproducible as reported — the test file was a valid .xlsx workbook and no uploaded file is written to disk. Upload validation was hardened regardless: file-signature (magic byte) verification, decompression and row limits, and server-side re-validation of all imported rows.

VA-004

Remediation: Upgraded @tiptap/core from 3.30.2 to 3.31.3.

VA-005

Remediation: Upgraded nodemailer from 9.0.5 to 9.1.1.

VA-006

Remediation: Upgraded fast-uri from 3.1.5 to 3.1.8 via dependency override.

VA-007

Remediation: Upgraded hono from 4.13.3 to 4.13.8 via dependency override.

VA-008

Remediation: Upgraded mysql2 from 3.15.3 to 3.24.4 via dependency override. Prisma schema validation and client generation confirmed against the upgraded version.

VA-009

Remediation: Upgraded sharp from 0.35.3 to 0.35.4 and verified the resolved dependency tree.

VA-010

Remediation: No change required. The installed version 0.20.3 already post-dates both CVEs (fixed in 0.19.3 and 0.20.2) and is obtained from the vendor CDN with a pinned integrity hash.

VA-011

Remediation: Upgraded `@tiptap/core` to 3.31.3. Note that the recommended target of 3.30.4 remains affected; the fixed release is 3.30.5, as stated in VA-004.

VA-012

Remediation: Single active session enforced per account using a server-side token version counter; establishing a new session invalidates all others. Session timeout corrected to operate as a 15-minute inactivity timeout.

VA-013

Remediation: Password change and password reset now invalidate all active sessions within the same transaction as the credential update and force re-authentication. The same treatment was extended to email address changes.

VA-014

Remediation: A single password policy is now applied across registration, password change and password reset; the reset path previously enforced weaker rules. A blocklist was added covering common passwords, institution-specific terms, character-substitution variants and predictable sequences.

VA-015

Remediation: Open. Removal of `'unsafe-inline'` from the `style-src` directive is under feasibility assessment, as the directive is currently required by runtime inline styles from the UI component libraries.

VA-016

Remediation: Server-side password history enforcement implemented. The five most recently used password hashes are retained per account, and a new password is rejected if it matches any of them or the current password. Enforced on both the password-change and password-reset paths, the latter covering administrator-initiated resets.

VA-017

Remediation: Upgraded `nodemailer` from 9.1.1 to 10.0.12. The `@types/nodemailer` package was removed, as version 10 supplies its own TypeScript definitions. The Node.js 20+ requirement introduced by this release is satisfied by the runtime upgrade noted under VA-002.

VA-018

Remediation: No patched release of braces exists; 3.0.3 remains the latest published version. The dependency chain was removed instead. The patch-package dependency named in the finding was unused and has been deleted, and `tailwindcss-animate` was moved to development dependencies, as it is a build-time CSS plugin that was peer-pulling Tailwind into the production tree. braces is now absent from the production dependency tree (`npm ls braces --omit=dev` returns empty) and remains only in build tooling. The package will be monitored for a security update.